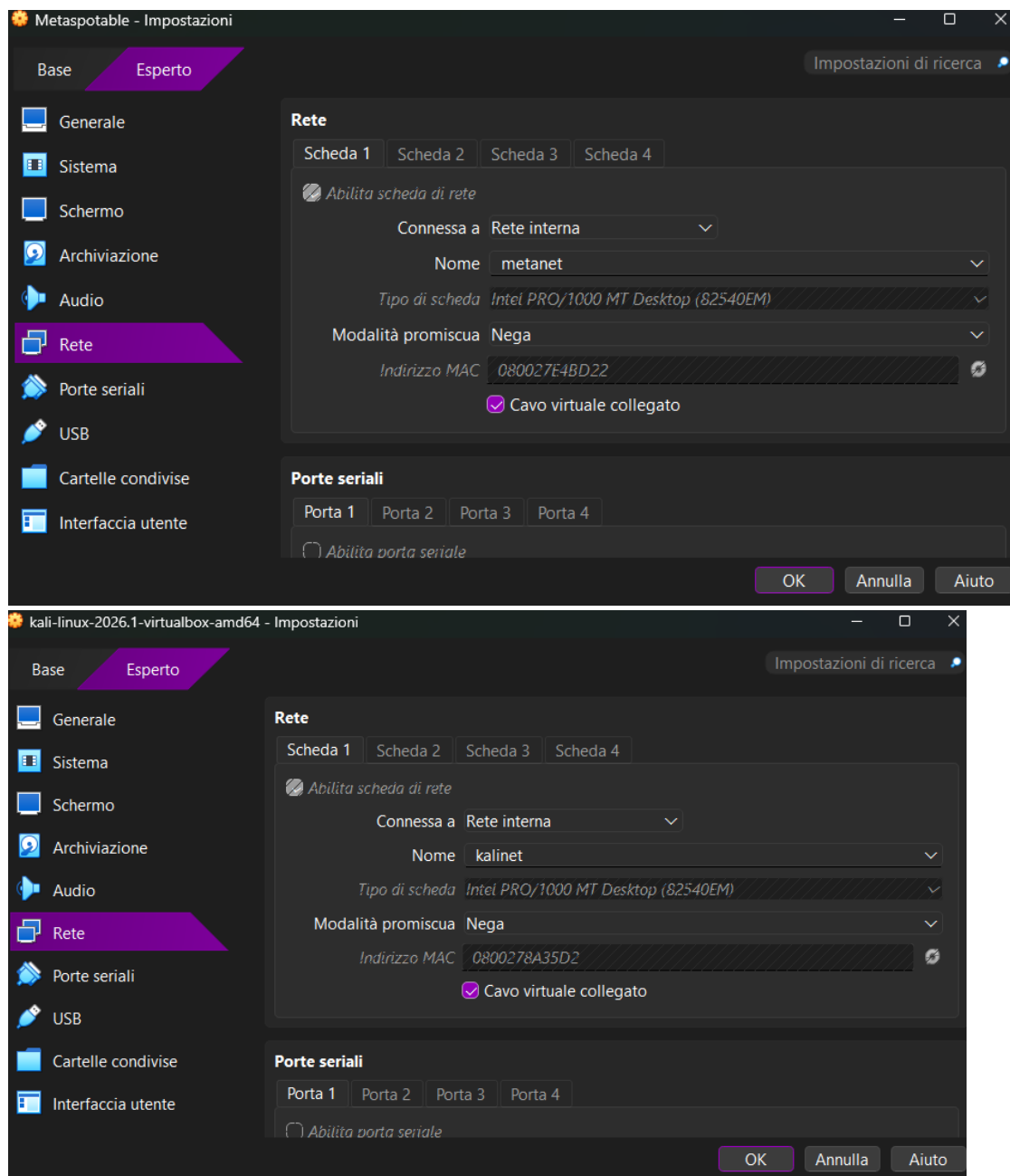


RELAZIONE TECNICA

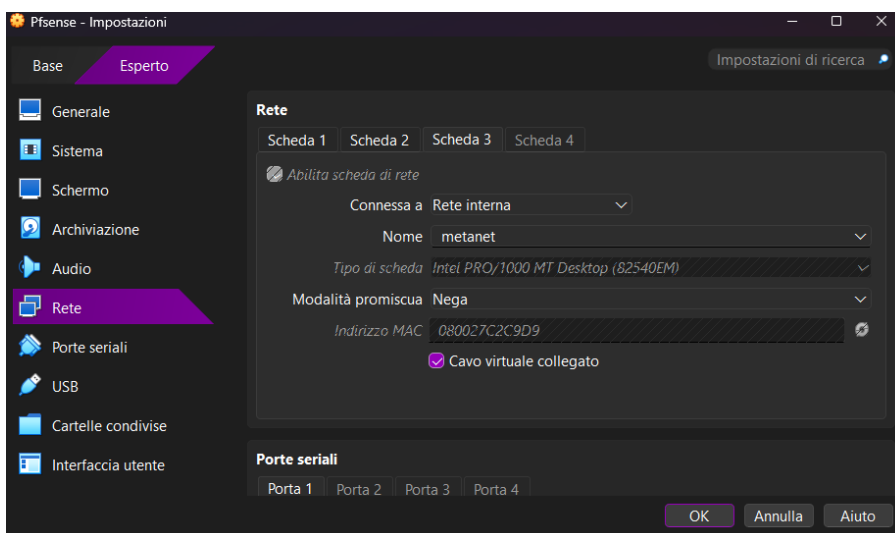
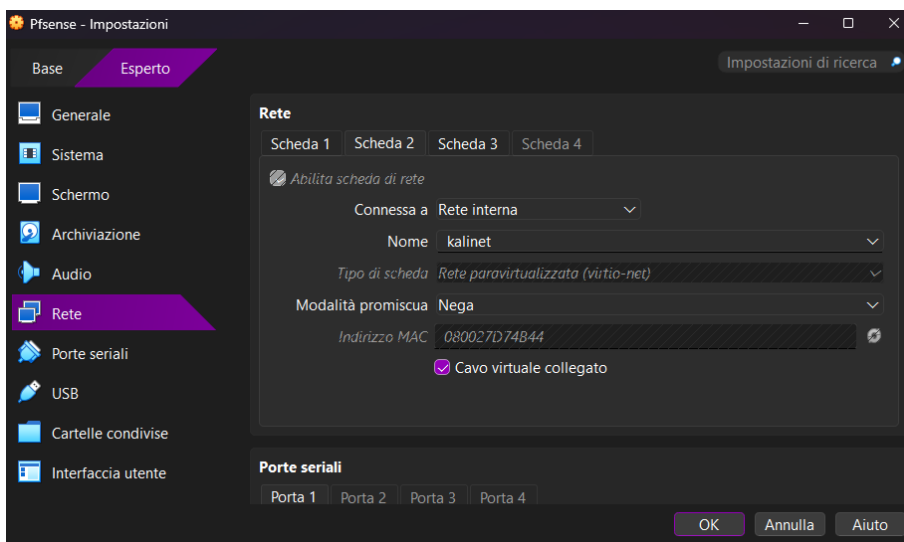
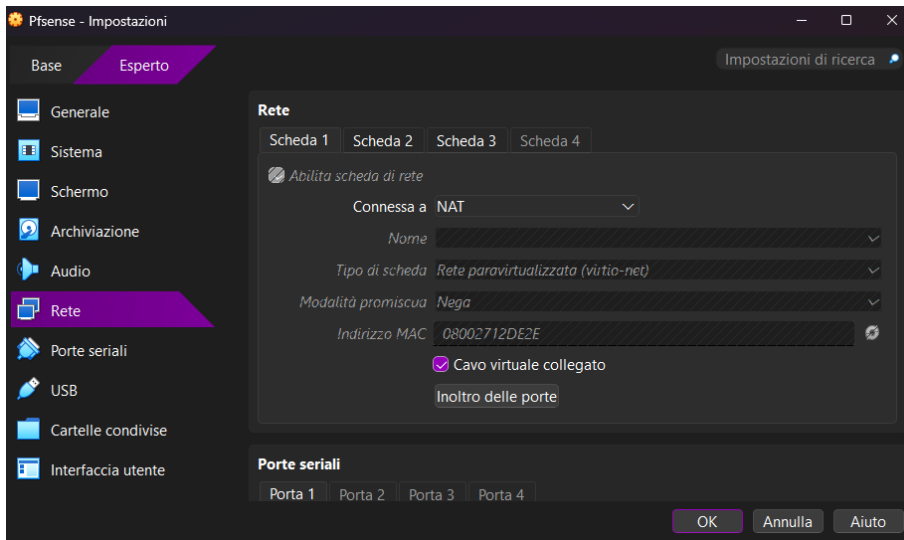
Obiettivo era la segmentazione della rete tramite il firewall pfSense per isolare due macchine collocate su subnet differenti: una macchina attaccante (Kali Linux) e una macchina target (Metasploitable che ospita la web app vulnerabile DVWA).

1. Svolgimento

Sono andato ad aprire virtual box, prima di lanciare le 3 macchine(kali, metasploitable e pfsense) ho settato le reti di ciascun dispositivo. Ho creato delle reti interne per la kali e la metasploitable



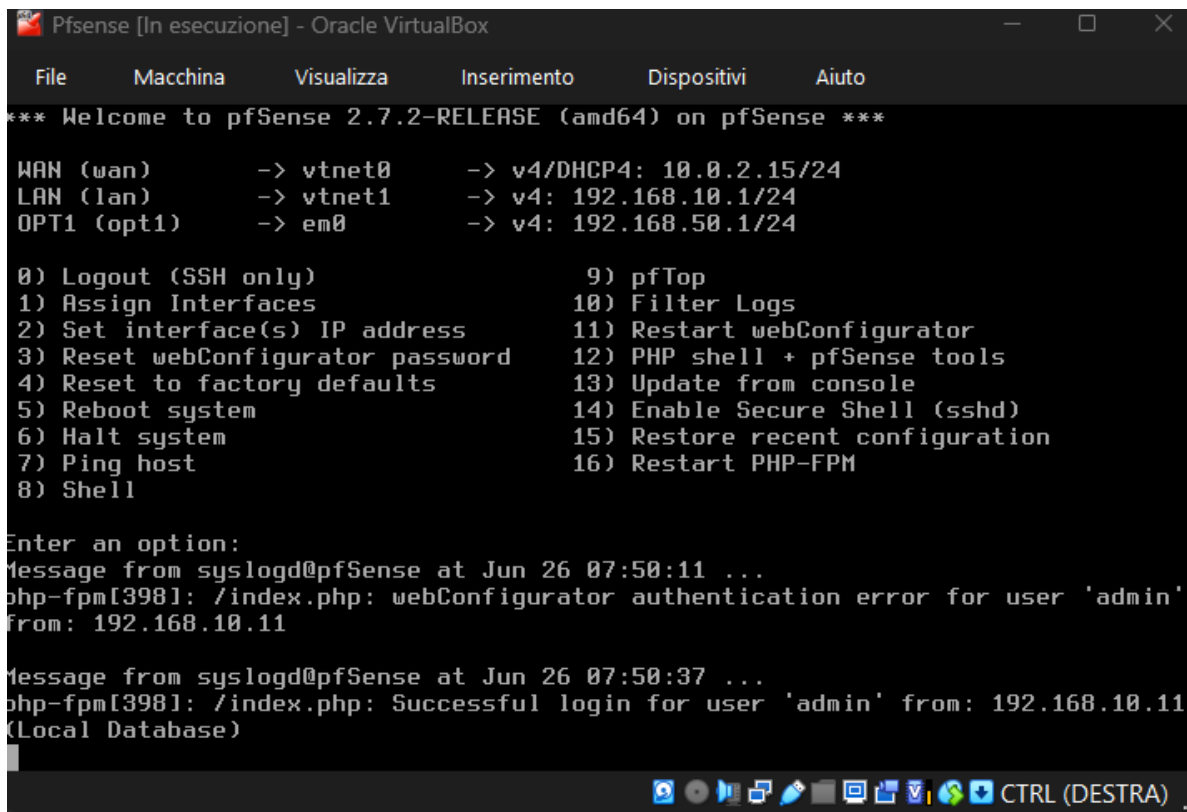
Successivamente ho settato anche la pfsense ma non in rete interna come le prime due, essendo che la pfsense farà da router quindi configuro 3 schede. La prima NAT o Bridge è indifferente, la seconda la configuro con la rete di kalinet(della kali) e la terza con la metanet (metaspolitable)



Ora si avviano tutt e 3 le macchine affinche funzioni il tutto.

2. Pfsense settings

Sulla prima parte ci si concentra solo su pfsense. Una volta avviato ci sarà la possibilità di scegliere varie funzioni



```
Pfsense [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

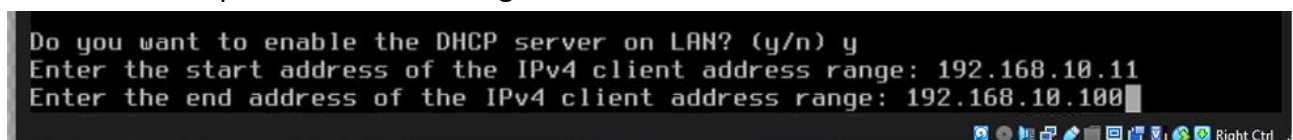
WAN (wan)      -> vtnet0      -> v4/DHCP4: 10.0.2.15/24
LAN (lan)      -> vtnet1      -> v4: 192.168.10.1/24
OPT1 (opt1)    -> em0         -> v4: 192.168.50.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults    13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option:
Message from syslogd@pfSense at Jun 26 07:50:11 ...
php-fpm[398]: /index.php: webConfigurator authentication error for user 'admin'
from: 192.168.10.11

Message from syslogd@pfSense at Jun 26 07:50:37 ...
php-fpm[398]: /index.php: Successful login for user 'admin' from: 192.168.10.11
(Local Database)
```

All'avvio abbiamo configurato le interfacce utilizzando l'opzione 1 e l'opzione 2 della console di pfSense. Sull'interfaccia LAN (vtnet1) abbiamo impostato l'indirizzo IP del gateway 192.168.10.1 e abbiamo attivato il server DHCP interno di pfSense, definendo un range di indirizzi IP da assegnare automaticamente ai client della rete (da 192.168.10.11 a 192.168.10.100). Sull'interfaccia OPT1 (em0), invece, abbiamo configurato l'IP statico 192.168.50.1 senza attivare il DHCP, poiché la macchina Metasploitable è stata configurata manualmente con IP statico



```
Do you want to enable the DHCP server on LAN? (y/n) y
Enter the start address of the IPv4 client address range: 192.168.10.11
Enter the end address of the IPv4 client address range: 192.168.10.100
```

ora rifacciamo le stesse cose con la em0 ma non offriamo il servizio DHCP.

3. Configurazione dei Client

Ho avviato i sistemi operativi ospiti (Kali Linux e Metasploitable) e ho verificato l'assegnazione degli indirizzi IP aprendo i rispettivi terminali e digitando il comando ip a:

Kali Linux ha ottenuto correttamente l'indirizzo 192.168.10.11 tramite il server DHCP di pfSense. Metasploitable è stata configurata staticamente con l'indirizzo IP 192.168.50.101.

```

msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:e4:bd:22 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.101/24 brd 192.168.50.255 scope global eth0
    inet6 fe80::a00:27ff:fee4:bd22/64 scope link
        valid_lft forever preferred_lft forever

```

```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.10.11/24 brd 192.168.10.255 scope global dynamic noprefixroute eth0
        valid_lft 6612sec preferred_lft 6612sec
    inet6 fe80::9fb1:a90d:e788:5b39/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

```

4. Regole del Firewall

Ora che abbiamo verificato tutto, andiamo sul browser della kali e digitiamo l'indirizzo IP del gateway della pfsense: 192.168.10.1 . Ci porta sul portale pfsense, ci logghiamo ed andiamo su firewall--> rules--> LAN.

Firewall / Rules / LAN

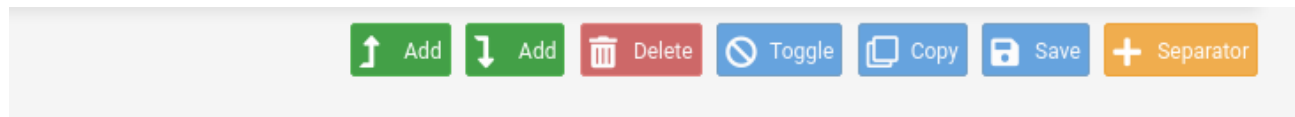
The changes have been applied successfully. The firewall rules are now reloading in the background. [Monitor the filter reload progress.](#)

Floating WAN LAN OPT1

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	1/312 KIB	*	*	*	LAN Address	80	*	*		Anti-Lockout Rule	
☐	0/0 B	IPv4 *	192.168.10.11	*	192.168.50.101	*	*	none			
☐	0/0 B	IPv4 TCP	LAN subnets	*	192.168.50.101	80 (HTTP)	*	none			
☐	1/1.42 MIB	IPv4 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	
☐	0/0 B	IPv6 *	LAN subnets	*	*	*	*	none		Default allow LAN to any rule	

Ora quando lo apriremo per la prima volta, la X non ci apparirà(sta ad indicare un blocco). Andiamo su add(freccia in su perchè la vogliamo in cima alla lista)



Andiamo a bloccare

Edit Firewall Rule

Action

Block

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled

☐ Disable this rule

Set this option to disable this rule without removing it from the list.

Interface

LAN

Choose the interface from which packets must come to match this rule.

Address Family

IPv4

Select the Internet Protocol version this rule applies to.

Protocol

Any

Choose which IP protocol this rule should match.

Scegliamo l'indirizzo della kali nella Source e della metaspolitable nella Destination

Source

Source

☐ Invert match

Address or Alias

192.168.10.11

/

Destination

Destination

☐ Invert match

Address or Alias

192.168.50.101

/

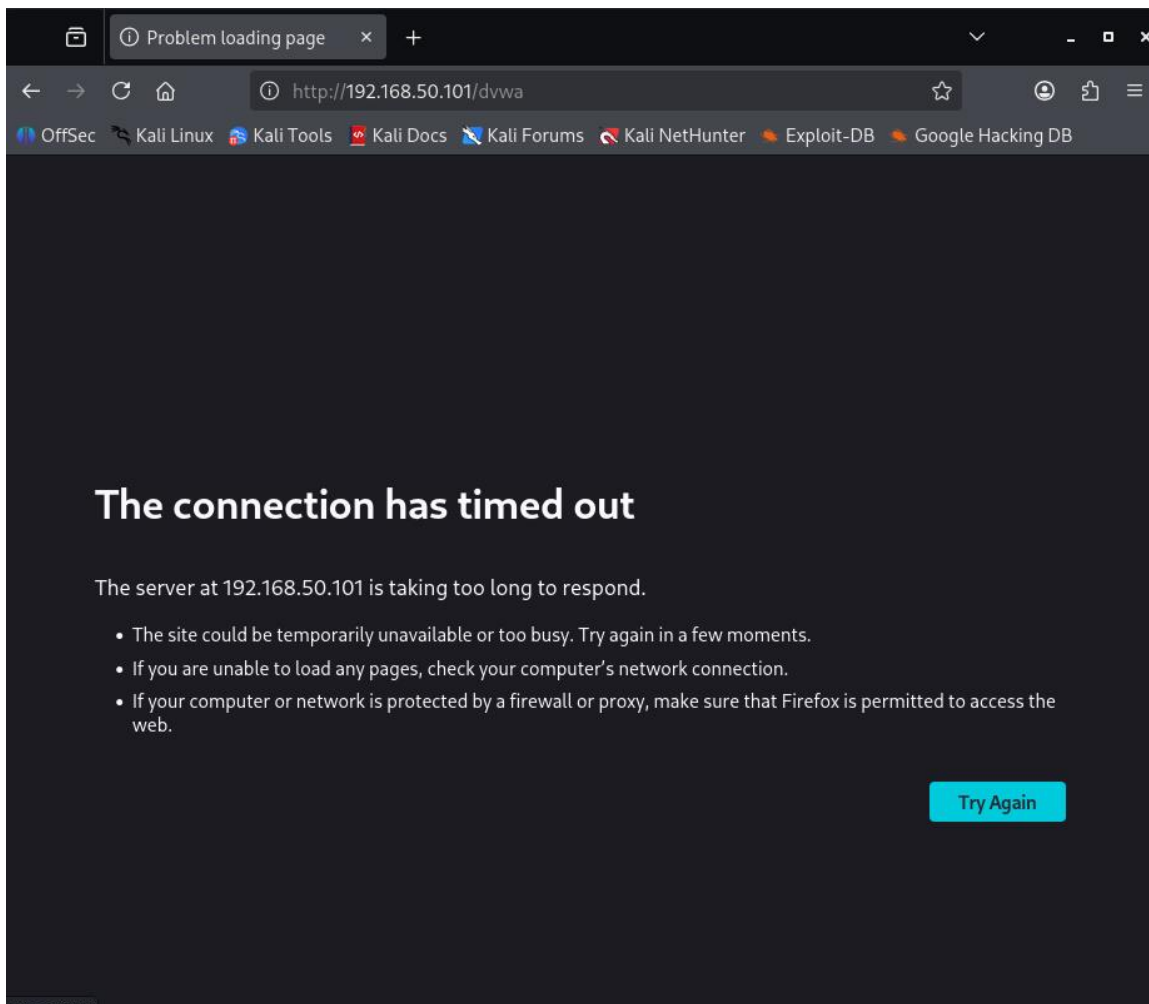
Poi salviamo e clicchiamo "apply changes" per confermare. Apparirà così:

☐	☒	0/96 KiB	IPv4 *	192.168.10.11 *	192.168.50.101 *	*	none	
--------------------------	-------------------------------------	-------------	--------	-----------------	------------------	---	------	--

5. Verifica Finale

Per convalidare l'efficacia della contromisura e dimostrare il reale isolamento della risorsa, sono stati eseguiti due test di verifica direttamente dalla macchina Kali Linux:

- Test di connettività di rete (Ping): Lanciando dal terminale di Kali il comando ping 192.168.50.101, i pacchetti ICMP Echo Request sono stati intercettati e distrutti dal firewall. Il terminale è rimasto in attesa indefinita evidenziando un Request Timeout e una perdita totale dei dati (100% packet loss), provando il corretto funzionamento della regola di tipo *Block*.
- Test applicativo Web (Accesso alla DVWA): Tentando di raggiungere la piattaforma web vulnerabile digitando l'indirizzo `http://192.168.50.101/dvwa/` nel browser di Kali Linux, la connessione è fallita. Il firewall ha scartato le richieste HTTP e il browser ha terminato la sessione mostrando l'errore di Connessione Scaduta (Timeout).



```
(kali㉿kali)-[~]  
$ ping 192.168.50.101  
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.  
^C  
— 192.168.50.101 ping statistics —  
93 packets transmitted, 0 received, 100% packet loss, time 94789ms
```

Dopo un lungo caricamento avremo questa schermata, anche andando a digitare il dvwa, non riuscirà ad aprirlo.